

# Guía de implementación de IAM

Usuarios, políticas y roles de servicio del proyecto Costa Gas Trujillo · Big Data UPAO 2026-20 · Cuenta de AWS del equipo, región us-east-2 (asignada por el plan gratuito) · Basada en el informe v6 (Tabla 3.12), el Plan de Corrección (hallazgo C7, WP 1.6) y la rotación de roles de la Semana 8.

## 1. Qué se va a crear

| Elemento                | Cantidad       | Nombres                                                                                                                                   | Cuándo       |
|-------------------------|----------------|-------------------------------------------------------------------------------------------------------------------------------------------|--------------|
| Políticas propias       | 5 + 1 opcional | costagas-base, costagas-ingenieria-datos, costagas-analitica, costagas-gobierno, costagas-powerbi-lectura; opcional costagas-emr-opcional | Hoy          |
| Usuarios de persona     | 4              | frank.trelles, anghelo.alcantara, wilson.mirano, bruno.ordonez                                                                            | Hoy          |
| Usuario técnico         | 1              | svc-powerbi                                                                                                                               | Semana 12    |
| Roles de servicio       | 2              | costagas-lambda-role, costagas-glue-role (los crea el stack)                                                                              | Al desplegar |
| Identidad de emergencia | 1              | Builder ID del titular (Google + MFA). Sin claves de acceso.                                                                              | Ya existe    |

### Principios del diseño

- **Un usuario por persona, ninguno compartido.** CloudTrail registra quién ejecutó cada acción, igual que Git registra quién escribió cada commit. Es la base del informe individual de la Semana 14.
- **Permisos por función, no por persona.** Los roles rotan en la Semana 8: se cambia la política adjunta y no se rediseña nada.
- **Mínimo privilegio.** Solo ingeniería de datos ve Bronze, donde están los datos crudos con nombres y DNI.
- **Separación de funciones.** Quien valida y documenta puede ver todo y no puede modificar nada.
- **Las denegaciones ganan.** costagas-base prohíbe a todos lo que el proyecto descartó, aunque otra política lo permita por error.

### Asignación por período

| Usuario           | Semanas 2–7                                 | Semanas 8–14                                | Clave de acceso (CLI) |
|-------------------|---------------------------------------------|---------------------------------------------|-----------------------|
| frank.trelles     | costagas-ingenieria-datos                   | costagas-analitica                          | Sí, en ambos períodos |
| wilson.mirano     | costagas-analitica                          | costagas-ingenieria-datos                   | Sí, en ambos períodos |
| anghelo.alcantara | costagas-gobierno (coordinación)            | costagas-gobierno (calidad y documentación) | No; solo consola      |
| bruno.ordonez     | costagas-gobierno (calidad y documentación) | costagas-gobierno (coordinación)            | No; solo consola      |
| Los cuatro        | costagas-base                               | costagas-base                               | —                     |

## 2. Antes de empezar

Todo este procedimiento lo ejecuta **el titular de la cuenta**, con su sesión de consola. Tiempo estimado: 45 minutos.

1. Entre a la consola del proyecto (Proyectos → Consola de AWS) y verifique que la región sea **us-east-2**.
2. Abra **IAM** desde el buscador. Anote el número de cuenta de 12 dígitos: lo necesitan los integrantes para iniciar sesión.
3. Compruebe tres cosas y anótelas: (a) que **Políticas** → **Crear política** ofrece un editor JSON; (b) que **Usuarios de IAM** → **Crear usuario** existe; (c) si aparece la opción **Grupos de usuarios**.

**Si su consola no coincide con esta guía.** La cuenta usa la experiencia nueva de AWS (plan gratuito, Builder ID) y su menú de IAM es reducido. Si (a) o (b) no están disponibles, deténgase: los integrantes tendrían que incorporarse por la sección **Equipo** y el procedimiento cambia. Si (c) no existe, no importa: esta guía adjunta las políticas directamente a cada usuario.

### 3. Paso 1 · Crear las políticas

Repita este procedimiento para cada política de esta sección:

1. IAM → **Políticas** → **Crear política**.
2. Cambie del editor visual a la pestaña **JSON** y borre el contenido de ejemplo.
3. Pegue el JSON completo de la política. Si la consola marca un error de sintaxis, revise que no falte la primera ni la última llave.
4. **Siguiente** → escriba el **nombre exacto** que indica esta guía → **Crear política**.

Los ARN usan comodines (costagas-trujillo-lake-\*, cuenta \*) para que el mismo JSON sirva con cualquier sufijo de bucket. Las condiciones por prefijo y por nombre costagas-\* son las que limitan el alcance.

#### costagas-base

| Aspecto       | Detalle                                                                                                                                                                                                       |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Se adjunta a  | Los cuatro usuarios de persona.                                                                                                                                                                               |
| Permite       | Que cada usuario administre su propia contraseña, su clave de acceso y su dispositivo MFA.                                                                                                                    |
| No permite    | Actuar fuera de us-east-2; usar EC2, NAT Gateway, QuickSight, claves KMS propias, crawlers de Glue, EMR Serverless, SageMaker, Redshift o RDS; crear usuarios o políticas; quitar el MFA; poner ACL públicas. |
| Justificación | Protege el tope de US\$ 1 y la regla de región única. Como son denegaciones explícitas, prevalecen sobre cualquier permiso. La gestión de identidades queda solo en el titular.                               |

JSON para pegar en la consola (1374 de 6 144 caracteres permitidos):

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "GestionarSuPropiaClaveYMFA",
      "Effect": "Allow",
      "Action": [
        "iam:GetUser", "iam:ChangePassword", "iam:CreateAccessKey", "iam:DeleteAccessKey",
        "iam:UpdateAccessKey", "iam:ListAccessKeys", "iam:EnableMFADevice",
        "iam:ResyncMFADevice", "iam:ListMFADevices", "iam:CreateVirtualMFADevice",
        "iam:ListVirtualMFADevices"
      ],
      "Resource": [
        "arn:aws:iam::*:user/${aws:username}", "arn:aws:iam::*:mfa/*"
      ]
    },
    {
      "Sid": "SoloUsEast2",
      "Effect": "Deny",
      "NotAction": [
        "iam:*", "sts:*", "budgets:*", "ce:*", "billing:*", "account:*", "support:*",
        "s3:ListAllMyBuckets", "s3:GetBucketLocation"
      ],
      "Resource": "*",
      "Condition": {"StringNotEquals": {"aws:RequestedRegion": "us-east-2"}}
    },
    {
      "Sid": "ServiciosConCostoFijo",
      "Effect": "Deny",
      "Action": [
        "ec2:RunInstances", "ec2:CreateNatGateway", "quicksight:*", "kms:CreateKey",
        "glue:CreateCrawler", "glue:StartCrawler", "emr-serverless:*", "sagemaker:*",
        "redshift:*", "rds:*"
      ],
      "Resource": "*"
    },
    {
      "Sid": "SoloElTitularGestionaIdentidades",
      "Effect": "Deny",
      "Action": [
        "iam:CreateUser", "iam:DeleteUser", "iam:AttachUserPolicy", "iam:DetachUserPolicy",
        "iam:PutUserPolicy", "iam:DeleteUserPolicy", "iam:CreatePolicy",

```

```

        "iam:CreatePolicyVersion", "iam:DeletePolicy", "iam:SetDefaultPolicyVersion",
        "iam:DeactivateMFADevice", "iam:DeleteVirtualMFADevice"
    ],
    "Resource": "*"
},
{
    "Sid": "SinAclPublicas",
    "Effect": "Deny",
    "Action": [
        "s3:PutBucketAcl", "s3:PutObjectAcl"
    ],
    "Resource": "*"
}
]
}

```

## costagas-ingenieria-datos

| Aspecto              | Detalle                                                                                                                                                                                            |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Se adjunta a</b>  | Frank (Semanas 2–7) · Wilson (Semanas 8–14).                                                                                                                                                       |
| <b>Permite</b>       | Desplegar el stack, cargar a Bronze, operar Lambda y Glue, crear tablas en Athena, guardar la sal en Parameter Store y crear roles de servicio cuyo nombre empiece por costagas-.                  |
| <b>No permite</b>    | Crear usuarios, cambiar sus propios permisos, entregar roles a servicios distintos de Lambda y Glue, ni tocar recursos que no sean del proyecto.                                                   |
| <b>Justificación</b> | Es el único perfil con acceso a Bronze y con permisos de escritura, por eso lo tiene una sola persona a la vez. El permiso sobre IAM es necesario porque el stack crea los roles de Lambda y Glue. |

JSON para pegar en la consola (2561 de 6 144 caracteres permitidos):

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "StacksDelProyecto",
      "Effect": "Allow",
      "Action": "cloudformation:*",
      "Resource": "arn:aws:cloudformation:us-east-2:*:stack/costagas-*/*"
    },
    {
      "Sid": "ValidarYListarStacks",
      "Effect": "Allow",
      "Action": [
        "cloudformation:ValidateTemplate", "cloudformation:ListStacks",
        "cloudformation:GetTemplateSummary"
      ],
      "Resource": "*"
    },
    {
      "Sid": "LagoYCodigo",
      "Effect": "Allow",
      "Action": "s3:*",
      "Resource": [
        "arn:aws:s3:::costagas-trujillo-lake-*", "arn:aws:s3:::costagas-trujillo-lake-*/*",
        "arn:aws:s3:::costagas-code-*", "arn:aws:s3:::costagas-code-*/*"
      ]
    },
    {
      "Sid": "ListarBuckets",
      "Effect": "Allow",
      "Action": "s3:ListAllMyBuckets",
      "Resource": "*"
    },
    {
      "Sid": "FuncionesDelProyecto",
      "Effect": "Allow",
      "Action": "lambda:*",
      "Resource": "arn:aws:lambda:us-east-2:*:function:costagas-*"
    },
    {
      "Sid": "CapasYListado",
      "Effect": "Allow",
      "Action": [
        "lambda:GetLayerVersion", "lambda:ListFunctions", "lambda:ListLayers"
      ]
    }
  ]
}

```

```

    ],
    "Resource": "*"
  },
  {
    "Sid": "GlueJobsYCatalogo",
    "Effect": "Allow",
    "Action": "glue:*",
    "Resource": "*"
  },
  {
    "Sid": "AthenaWorkgroup",
    "Effect": "Allow",
    "Action": "athena:*",
    "Resource": "arn:aws:athena:us-east-2:*:workgroup/costagas-wg"
  },
  {
    "Sid": "ListarAthena",
    "Effect": "Allow",
    "Action": [
      "athena:ListWorkGroups", "athena:ListDataCatalogs", "athena:GetDataCatalog",
      "athena:ListDatabases", "athena:GetDatabase", "athena:ListTableMetadata",
      "athena:GetTableMetadata"
    ],
    "Resource": "*"
  },
  {
    "Sid": "SalDeSeudonimizacion",
    "Effect": "Allow",
    "Action": [
      "ssm:GetParameter", "ssm:GetParameters", "ssm:PutParameter", "ssm>DeleteParameter",
      "ssm:AddTagsToResource"
    ],
    "Resource": "arn:aws:ssm:us-east-2:*:parameter/costagas/*"
  },
  {
    "Sid": "ListarParametros",
    "Effect": "Allow",
    "Action": "ssm:DescribeParameters",
    "Resource": "*"
  },
  {
    "Sid": "RolesDeServicioDelProyecto",
    "Effect": "Allow",
    "Action": [
      "iam:CreateRole", "iam>DeleteRole", "iam:GetRole", "iam:TagRole",
      "iam:UpdateAssumeRolePolicy", "iam:PutRolePolicy", "iam>DeleteRolePolicy",
      "iam:GetRolePolicy", "iam:ListRolePolicies", "iam:AttachRolePolicy",
      "iam:DetachRolePolicy", "iam:ListAttachedRolePolicies"
    ],
    "Resource": "arn:aws:iam::*:role/costagas-*"
  },
  {
    "Sid": "EntregarRolesSoloALambdaYGlue",
    "Effect": "Allow",
    "Action": "iam:PassRole",
    "Resource": "arn:aws:iam::*:role/costagas-*",
    "Condition": {
      "StringEquals": {
        "iam:PassedToService": [
          "lambda.amazonaws.com",
          "glue.amazonaws.com"
        ]
      }
    }
  },
  {
    "Sid": "PresupuestoYCostos",
    "Effect": "Allow",
    "Action": [
      "budgets:*", "ce:Get*", "ce:Describe*"
    ],
    "Resource": "*"
  },
  {
    "Sid": "LeerLogs",
    "Effect": "Allow",

```

```

    "Action": [
      "logs:DescribeLogGroups", "logs:DescribeLogStreams", "logs:GetLogEvents",
      "logs:FilterLogEvents", "logs:StartQuery", "logs:GetQueryResults"
    ],
    "Resource": "*"
  }
]
}

```

## costagas-analítica

| Aspecto              | Detalle                                                                                                                                                                                      |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Se adjunta a</b>  | Wilson (Semanas 2–7) · Frank (Semanas 8–14).                                                                                                                                                 |
| <b>Permite</b>       | Leer Silver y Gold, consultar en Athena dentro del workgroup, leer el catálogo y lanzar corridas de los jobs de Glue existentes.                                                             |
| <b>No permite</b>    | Leer Bronze, escribir en Silver o Gold, crear o modificar jobs, tablas o funciones.                                                                                                          |
| <b>Justificación</b> | El v6 exige analizar «sobre Silver y Gold, nunca sobre los datos crudos»: aquí lo impone AWS. Los puntajes del modelo llegan a Gold a través del rol de Glue, no con permisos de la persona. |

JSON para pegar en la consola (1843 de 6 144 caracteres permitidos):

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ListarSoloSusPrefijos",
      "Effect": "Allow",
      "Action": [
        "s3:ListBucket", "s3:GetBucketLocation"
      ],
      "Resource": "arn:aws:s3:::costagas-trujillo-lake-*",
      "Condition": {"StringLike": {"s3:prefix": ["silver/*", "gold/*", "athena-results/*"]}}
    },
    {
      "Sid": "LeerCapasPermitidas",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": [
        "arn:aws:s3:::costagas-trujillo-lake-*/silver/*",
        "arn:aws:s3:::costagas-trujillo-lake-*/gold/*"
      ]
    },
    {
      "Sid": "ResultadosDeAthena",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject", "s3:PutObject", "s3:AbortMultipartUpload"
      ],
      "Resource": "arn:aws:s3:::costagas-trujillo-lake-*/athena-results/*"
    },
    {
      "Sid": "ConsultarEnElWorkgroup",
      "Effect": "Allow",
      "Action": [
        "athena:StartQueryExecution", "athena:StopQueryExecution", "athena:GetQueryExecution",
        "athena:GetQueryResults", "athena:GetQueryResultsStream",
        "athena:BatchGetQueryExecution", "athena:ListQueryExecutions", "athena:GetWorkGroup"
      ],
      "Resource": "arn:aws:athena:us-east-2:*:workgroup/costagas-wg"
    },
    {
      "Sid": "ListarAthena",
      "Effect": "Allow",
      "Action": [
        "athena:ListWorkGroups", "athena:ListDataCatalogs", "athena:GetDataCatalog",
        "athena:ListDatabases", "athena:GetDatabase", "athena:ListTableMetadata",
        "athena:GetTableMetadata"
      ],
      "Resource": "*"
    },
    {
      "Sid": "LeerCatalogo",
      "Effect": "Allow",

```

```

    "Action": [
      "glue:GetDatabase", "glue:GetDatabases", "glue:GetTable", "glue:GetTables",
      "glue:GetPartition", "glue:GetPartitions", "glue:BatchGetPartition"
    ],
    "Resource": "*"
  },
  {
    "Sid": "LanzarYVerCorridasDeGlue",
    "Effect": "Allow",
    "Action": [
      "glue:GetJob", "glue:GetJobs", "glue:StartJobRun", "glue:GetJobRun", "glue:GetJobRuns",
      "glue:BatchStopJobRun"
    ],
    "Resource": "arn:aws:glue:us-east-2:*.job/costagas-*"
  },
  {
    "Sid": "LeerLogsDeGlue",
    "Effect": "Allow",
    "Action": [
      "logs:DescribeLogGroups", "logs:DescribeLogStreams", "logs:GetLogEvents",
      "logs:FilterLogEvents", "logs:StartQuery", "logs:GetQueryResults"
    ],
    "Resource": "*"
  }
]
}

```

## costagas-gobierno

| Aspecto              | Detalle                                                                                                                                                                                                     |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Se adjunta a</b>  | Anghelo y Bruno, en ambos períodos.                                                                                                                                                                         |
| <b>Permite</b>       | Leer Silver y Gold, consultar en Athena, ver costos y presupuesto, y ver (sin modificar) IAM, CloudFormation, Lambda, Glue, la configuración del bucket, los logs y CloudTrail.                             |
| <b>No permite</b>    | Modificar cualquier recurso o leer Bronze.                                                                                                                                                                  |
| <b>Justificación</b> | Coordinación y calidad necesitan lo mismo: verificar que las cifras del informe salgan de Gold, medir el costo real y capturar la evidencia de seguridad. Quien valida no debe poder alterar lo que valida. |

JSON para pegar en la consola (2343 de 6 144 caracteres permitidos):

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ListarSoloSusPrefijos",
      "Effect": "Allow",
      "Action": [
        "s3:ListBucket", "s3:GetBucketLocation"
      ],
      "Resource": "arn:aws:s3:::costagas-trujillo-lake-*",
      "Condition": {"StringLike": {"s3:prefix": ["silver/*", "gold/*", "athena-results/*"]}}
    },
    {
      "Sid": "LeerCapasPermitidas",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": [
        "arn:aws:s3:::costagas-trujillo-lake-*/silver/*",
        "arn:aws:s3:::costagas-trujillo-lake-*/gold/*"
      ]
    },
    {
      "Sid": "ResultadosDeAthena",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject", "s3:PutObject", "s3:AbortMultipartUpload"
      ],
      "Resource": "arn:aws:s3:::costagas-trujillo-lake-*/athena-results/*"
    },
    {
      "Sid": "ConsultarEnElWorkgroup",
      "Effect": "Allow",
      "Action": [
        "athena:StartQueryExecution", "athena:StopQueryExecution", "athena:GetQueryExecution",

```

```

        "athena:GetQueryResults", "athena:GetQueryResultsStream",
        "athena:BatchGetQueryExecution", "athena:ListQueryExecutions", "athena:GetWorkGroup"
    ],
    "Resource": "arn:aws:athena:us-east-2:*:workgroup/costagas-wg"
},
{
    "Sid": "ListarAthena",
    "Effect": "Allow",
    "Action": [
        "athena:ListWorkGroups", "athena:ListDataCatalogs", "athena:GetDataCatalog",
        "athena:ListDatabases", "athena:GetDatabase", "athena:ListTableMetadata",
        "athena:GetTableMetadata"
    ],
    "Resource": "*"
},
{
    "Sid": "LeerCatalogoYJobs",
    "Effect": "Allow",
    "Action": [
        "glue:Get*", "glue:List*", "glue:BatchGet*"
    ],
    "Resource": "*"
},
{
    "Sid": "VerConfiguracionDelBucket",
    "Effect": "Allow",
    "Action": [
        "s3:GetBucketPolicy", "s3:GetEncryptionConfiguration", "s3:GetBucketPublicAccessBlock",
        "s3:GetLifecycleConfiguration", "s3:GetBucketVersioning", "s3:GetBucketNotification",
        "s3:ListAllMyBuckets"
    ],
    "Resource": "*"
},
{
    "Sid": "VerCostos",
    "Effect": "Allow",
    "Action": [
        "budgets:ViewBudget", "budgets:Describe*", "ce:Get*", "ce:Describe*", "ce:List*"
    ],
    "Resource": "*"
},
{
    "Sid": "AuditarSeguridad",
    "Effect": "Allow",
    "Action": [
        "iam:Get*", "iam:List*", "iam:GenerateCredentialReport", "access-analyzer:List*",
        "access-analyzer:Get*", "access-analyzer:ValidatePolicy", "cloudtrail:LookupEvents"
    ],
    "Resource": "*"
},
{
    "Sid": "VerInfraestructura",
    "Effect": "Allow",
    "Action": [
        "cloudformation:Describe*", "cloudformation:List*", "cloudformation:GetTemplate",
        "lambda:Get*", "lambda:List*"
    ],
    "Resource": "*"
},
{
    "Sid": "LeerLogs",
    "Effect": "Allow",
    "Action": [
        "logs:DescribeLogGroups", "logs:DescribeLogStreams", "logs:GetLogEvents",
        "logs:FilterLogEvents", "logs:StartQuery", "logs:GetQueryResults"
    ],
    "Resource": "*"
}
]
}

```

## costagas-powerbi-lectura

| Aspecto       | Detalle                                                                                   |
|---------------|-------------------------------------------------------------------------------------------|
| Se adjunta a  | svc-powerbi (Semana 12).                                                                  |
| Permite       | Leer Gold y ejecutar consultas en el workgroup.                                           |
| No permite    | Ver Silver, Bronze o cualquier otro servicio.                                             |
| Justificación | La clave del tablero queda guardada en una PC. Si se filtra, solo expone lectura de Gold. |

JSON para pegar en la consola (1498 de 6 144 caracteres permitidos):

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ListarSoloSusPrefijos",
      "Effect": "Allow",
      "Action": [
        "s3:ListBucket", "s3:GetBucketLocation"
      ],
      "Resource": "arn:aws:s3:::costagas-trujillo-lake-*",
      "Condition": {"StringLike": {"s3:prefix": ["gold/*", "athena-results/*"]}}
    },
    {
      "Sid": "LeerCapasPermitidas",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": [
        "arn:aws:s3:::costagas-trujillo-lake-*/gold/*"
      ]
    },
    {
      "Sid": "ResultadosDeAthena",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject", "s3:PutObject", "s3:AbortMultipartUpload"
      ],
      "Resource": "arn:aws:s3:::costagas-trujillo-lake-*/athena-results/*"
    },
    {
      "Sid": "ConsultarEnElWorkgroup",
      "Effect": "Allow",
      "Action": [
        "athena:StartQueryExecution", "athena:StopQueryExecution", "athena:GetQueryExecution",
        "athena:GetQueryResults", "athena:GetQueryResultsStream",
        "athena:BatchGetQueryExecution", "athena:ListQueryExecutions", "athena:GetWorkGroup"
      ],
      "Resource": "arn:aws:athena:us-east-2*:workgroup/costagas-wg"
    },
    {
      "Sid": "ListarAthena",
      "Effect": "Allow",
      "Action": [
        "athena:ListWorkGroups", "athena:ListDataCatalogs", "athena:GetDataCatalog",
        "athena:ListDatabases", "athena:GetDatabase", "athena:ListTableMetadata",
        "athena:GetTableMetadata"
      ],
      "Resource": "*"
    },
    {
      "Sid": "LeerSoloCatalogoGold",
      "Effect": "Allow",
      "Action": [
        "glue:GetDatabase", "glue:GetDatabases", "glue:GetTable", "glue:GetTables",
        "glue:GetPartition", "glue:GetPartitions", "glue:BatchGetPartition"
      ],
      "Resource": [
        "arn:aws:glue:us-east-2*:catalog", "arn:aws:glue:us-east-2*:database/costagas_gold",
        "arn:aws:glue:us-east-2*:table/costagas_gold/*"
      ]
    }
  ]
}
```

## costagas-emr-opcional

| Aspecto              | Detalle                                                                                                                                                                                                                  |
|----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Se adjunta a</b>  | Nadie por ahora. Solo si se actualiza la cuenta para usar EMR.                                                                                                                                                           |
| <b>Permite</b>       | Lanzar y apagar un clúster transitorio y agregarle pasos.                                                                                                                                                                |
| <b>No permite</b>    | Nada más.                                                                                                                                                                                                                |
| <b>Justificación</b> | EMR está bloqueado en el plan gratuito. Se deja creada para adjuntarla al usuario de ingeniería en la Semana 9, si el equipo decide actualizar la cuenta. Los roles por defecto de EMR los crea el titular una sola vez. |

JSON para pegar en la consola (505 de 6 144 caracteres permitidos):

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ClusterTransitorio",
      "Effect": "Allow",
      "Action": [
        "elasticmapreduce:RunJobFlow", "elasticmapreduce:AddJobFlowSteps",
        "elasticmapreduce:TerminateJobFlows", "elasticmapreduce:DescribeCluster",
        "elasticmapreduce:DescribeStep", "elasticmapreduce:ListClusters",
        "elasticmapreduce:ListSteps"
      ],
      "Resource": "*"
    },
    {
      "Sid": "RolesPorDefectoDeEMR",
      "Effect": "Allow",
      "Action": "iam:PassRole",
      "Resource": [
        "arn:aws:iam::*:role/EMR_DefaultRole", "arn:aws:iam::*:role/EMR_EC2_DefaultRole"
      ]
    }
  ]
}
```

## 4. Paso 2 · Crear los cuatro usuarios

Repita para cada integrante, con la política de función de la tabla «Asignación por período»:

1. IAM → **Usuarios de IAM** → **Crear persona**. Nombre: por ejemplo frank.trelles.
2. Marque **Proporcionar acceso de usuario a la consola de administración de AWS**.
3. Contraseña: **generada automáticamente** y marque **el usuario debe crear una contraseña nueva en el próximo inicio de sesión**.
4. Permisos → **Adjuntar políticas directamente** → marque costagas-base y **una sola** política de función.
5. **Crear usuario**. Descargue el archivo .csv con la URL de inicio de sesión y la contraseña temporal.
6. Entregue esos datos al integrante por un canal privado (en persona o mensaje directo), nunca por el grupo ni por el repositorio.

### Lo que hace cada integrante la primera vez

1. Abre la URL de inicio de sesión (<https://<cuenta>.signin.aws.amazon.com/console>), entra y cambia la contraseña.
2. Arriba a la derecha → **Credenciales de seguridad** → **Asignar dispositivo MFA** → aplicación de autenticación → escanea el QR e ingresa dos códigos consecutivos.
3. Cierra sesión y vuelve a entrar para comprobar que pide el código.

**Evidencia.** Captura de la lista de usuarios con la columna MFA activa para los cuatro: va a docs/evidencias/seguridad/ y a la sección 3.8 del informe.

## 5. Paso 3 · Clave de acceso para la terminal

Solo la crean quienes tienen costagas-ingenieria-datos o costagas-analitica. Cada uno la crea para sí mismo, con su propio usuario.

1. **Credenciales de seguridad** → **Claves de acceso** → **Crear clave de acceso** → caso de uso CLI.
2. Descargue el .csv y guárdelo fuera de la carpeta del repositorio. La clave secreta solo se muestra una vez.
3. Configure un perfil con nombre, para no mezclarlo con otras cuentas:

```
aws configure --profile costagas
# AWS Access Key ID: (pegar)
# AWS Secret Access Key: (pegar)
# Default region name: us-east-2
# Default output format: json

aws sts get-caller-identity --profile costagas
```

La respuesta debe mostrar el ARN del usuario, por ejemplo `arn:aws:iam::<cuenta>:user/frank.trelles`. Para no escribir `--profile` en cada comando, defina la variable `AWS_PROFILE=costagas` en la terminal.

**Nunca** pegue la clave en el chat, en capturas, en el código ni en .env versionado. Si una clave se expone, bórrala de inmediato en la consola y cree otra.

## 6. Paso 4 · Comprobar que los permisos funcionan

Estas pruebas son la evidencia del mínimo privilegio. Guarde la salida de cada una. Las tres primeras se pueden hacer hoy; las demás, después del despliegue.

| Usuario    | Comando                                                   | Resultado esperado                                   |
|------------|-----------------------------------------------------------|------------------------------------------------------|
| Cualquiera | <code>aws iam create-user --user-name prueba</code>       | AccessDenied con «explicit deny» (costagas-base)     |
| Cualquiera | <code>aws lambda list-functions --region sa-east-1</code> | AccessDenied con «explicit deny»: fuera de us-east-2 |

| Usuario    | Comando                                                                                                      | Resultado esperado                                       |
|------------|--------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|
| Cualquiera | <code>aws ec2 run-instances --image-id ami-0<br/>--instance-type t3.micro</code>                             | UnauthorizedOperation: servicio con costo fijo, denegado |
| Analítica  | <code>aws s3 ls<br/>s3://costagas-trujillo-lake-&lt;sufijo&gt;/bronze/</code>                                | AccessDenied: no ve los datos crudos                     |
| Analítica  | <code>aws s3 ls s3://costagas-trujillo-lake-&lt;sufijo&gt;/gold/</code>                                      | Lista el contenido                                       |
| Analítica  | <code>aws s3 cp x.txt<br/>s3://costagas-trujillo-lake-&lt;sufijo&gt;/gold/x.txt</code>                       | AccessDenied: no escribe en Gold                         |
| Gobierno   | En la consola: intentar borrar un objeto de silver/                                                          | Acceso denegado                                          |
| Gobierno   | En la consola: abrir Budgets y Cost Explorer                                                                 | Puede ver el presupuesto y el gasto                      |
| Ingeniería | <code>aws cloudformation validate-template --template-body<br/>file://infra/cloudformation/stack.yaml</code> | Devuelve los parámetros de la plantilla                  |

Por último, en IAM → **Analizador de acceso**, valide cada política: no debe reportar errores de seguridad.

## 7. Paso 5 · Roles de servicio

No son usuarios: los asumen Lambda y Glue al ejecutarse. Los crea el stack de CloudFormation, pero hoy tienen más alcance del que declara el informe v6. Estos cambios se aplican al repositorio cuando el equipo lo apruebe:

| Rol                  | Hoy                                 | Corrección                                                              | Motivo                                                       |
|----------------------|-------------------------------------|-------------------------------------------------------------------------|--------------------------------------------------------------|
| costagas-lambda-role | Lee todo bronze/*                   | Lee solo bronze/interno/*; escribe silver/*; lee el parámetro de la sal | La Lambda solo limpia los archivos internos                  |
| costagas-glue-role   | Lee silver/* y solo el padrón SUNAT | Lee bronze/externo/* y silver/*; escribe silver/* y gold/*              | El job de externos procesa GDELT, resoluciones y Facilito    |
| Nombres              | Generados por CloudFormation        | Nombres fijos costagas-*-role                                           | Coinciden con el v6; exige CAPABILITY_NAMED_IAM en deploy.sh |

## 8. Paso 6 · Rotación de la Semana 8

1. El titular quita costagas-ingenieria-datos a Frank y se la adjunta a Wilson; quita costagas-analitica a Wilson y se la adjunta a Frank.
2. Frank y Wilson **borran su clave de acceso anterior** y crean una nueva.
3. Anghelo y Bruno conservan costagas-gobierno; solo cambia su tarea.
4. Se repiten las pruebas del paso 4 con los nuevos perfiles.
5. Se registra la rotación en un ADR, con captura de los permisos antes y después.

## 9. Paso 7 · Usuario del tablero (Semana 12)

1. Crear el usuario svc-powerbi **sin** acceso a la consola.
2. Adjuntar solo costagas-powerbi-lectura.
3. Crear su clave de acceso y configurarla en el controlador ODBC de Athena en la PC del tablero (workgroup costagas-wg).
4. Borrar la clave al terminar el proyecto.

## 10. Qué documentar

| Dónde      | Qué                                                                             |
|------------|---------------------------------------------------------------------------------|
| infra/iam/ | Los JSON de esta guía, uno por archivo, y un README con la matriz de asignación |

| Dónde                       | Qué                                                                                                                                                                                         |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| docs/adr/                   | ADR «Usuarios por persona y permisos por función», con las alternativas descartadas (un solo usuario administrador; usuario compartido; IAM Identity Center, bloqueado en el plan gratuito) |
| docs/evidencias/seguridad/  | Capturas de políticas, usuarios con MFA y salidas de las pruebas del paso 4                                                                                                                 |
| <b>Informe, sección 2.4</b> | Equivalencias con la ruta on-premise: Kerberos ↔ usuarios de IAM con MFA; Apache Ranger ↔ políticas por prefijo; cifrado HDFS ↔ SSE-S3 y TLS                                                |
| <b>Informe, sección 3.8</b> | Tabla 3.12 actualizada con los nombres reales de políticas y roles                                                                                                                          |

## Errores frecuentes

| Síntoma                                | Causa probable                                               | Solución                                                               |
|----------------------------------------|--------------------------------------------------------------|------------------------------------------------------------------------|
| <b>«explicit deny» al desplegar</b>    | costagas-base bloquea la región o un servicio descartado     | Confirmar --region us-east-2 y que el stack no use recursos prohibidos |
| <b>AccessDenied en iam:PassRole</b>    | El rol no empieza por costagas- o se entrega a otro servicio | Usar los nombres de esta guía                                          |
| <b>Athena no lista las tablas</b>      | La consulta no usa el workgroup costagas-wg                  | Seleccionar el workgroup antes de consultar                            |
| <b>No puede listar una carpeta</b>     | El prefijo no termina en / o no es silver/gold               | Listar silver/<tabla>/                                                 |
| <b>Un integrante perdió el celular</b> | MFA inaccesible                                              | El titular desactiva su MFA y el integrante registra uno nuevo         |